



Analysis of the Supply Chain Cyberattack Against SolarWinds

- Deligiannis Nikolaos (3230041)
- Paulou Antonios (3230163)

Part A: Summary Presentation of the Attack

The supply chain cyber attack against the American technology company SolarWinds is one of the most significant attacks on the modern cybersecurity space, redefining the definition of digital trust and safe coding. The SolarWinds Orion platform, the focal point of the breach, is leading software for network monitoring and management. By its nature, this software requires elevated administrative privileges to collect telemetry, monitor performance, and manage configurations across an organization's entire IT infrastructure. At the time of the attack, the product had approximately 33,000 customers worldwide, including more than 425 Fortune 500 companies and nearly all U.S. federal agencies. This highly privileged position within networks made SolarWinds the ideal intermediate target for highly skilled attackers.

The initial penetration most likely happened in September 2019. The attackers demonstrated unprecedented operation security and strategic patience by not proceeding with immediate destructive action, but instead wait. They spent months understanding the company's internal software build environment. In February 2020, the attackers managed to integrate a malicious backdoor, named SUNBURST, into the source code of official ORION updates. Given that the code was compiled and digitally signed with SolarWinds' own valid cryptographic certificates, these updates were considered perfectly legitimate by customers' security systems.

From March up to June 2020, the malicious updates were installed in approximately 18000 organizations. However, the attackers operated with high precision and attacked less than 100 high value targets. The reveal of the attack did not come from SolarWinds or one of these organizations but from a cyber security firm called FireEye, which in September 2020 announced that they had fallen into a high sophisticated attack leading to the theft of their internal Red Team tools. Their internal investigation revealed that the penetration into its network originated from SolarWinds Orion software. The official announcement in 13 of December 2020 caused global mobilization.

The extent of the attack and the impact of it, often referred as StellarParticle, were devastating. Confirmed victims include top tech companies such as Microsoft, Cisco, VMware, Palo Alto Networks and MimeCast. Even more alarming is the penetration in 9 critical national USA federal agencies, including the Department of Defense, the Treasury Department, the Department of Homeland Security, the State Department, and the National Nuclear Security Administration. This access allowed the attackers to steal critical data and sensitive email for months, mostly exploiting Microsoft 365.

In April 2021, the United States government, in coordination with the United Kingdom, officially attributed responsibility for the attack to Russia's Foreign Intelligence Service (SVR). Threat analysts identify the group behind the attack with the names APT29, NOBELIUM, UNC2452, Dark Halo, and Cozy Bear. The success of APT29 confirmed a structural weakness in the global technological ecosystem: blind trust in third-party vendor software. According to subsequent analyses, such as those recorded in the 2025 Threat Landscape report by the European Union Agency for Cybersecurity (ENISA), supply chain attacks have now become industrialized, offering threat actors asymmetric results by allowing them to simultaneously breach thousands of high-maturity environments through a single trusted channel.

During the investigation, a second backdoor in the form of a webshell, known as SUPERNOVA, was also identified on SolarWinds systems. However, extensive technical analyses confirmed that SUPERNOVA was an entirely independent zero-day exploit by a different threat actor and was not related to APT29's SUNBURST attack campaign.

Part B: Detailed Technical Analysis of the Attack (Stages and Timeline)

The way APT29 attacked is characterized by a strict division of phases, which goal is to minimize its footprint. To fully understand the complexity of the penetration, mapping the key events is essential.

Full Timeline of the attack

Time Period / Date	Event Description
August - September 2019	APT29 group gains initial unauthorized access to SolarWinds' corporate network
October 2019	Execution of the first code injection dry runs in the Orion development system to confirm the ability to alter code without causing compilation errors.
February 20, 2020	The specialized SUNSPOT malware is fully deployed and begins the active integration of the SUNBURST malicious code into official Orion releases
March - June 2020	Altered but digitally signed versions of Orion (from 2019.4 to 2020.2.1) are distributed and installed in approximately 18,000 customers worldwide.
May - June 2020	Attackers begin targeted lateral movement and deployment of additional implants (such as TEARDROP) in selected victim networks.
June 4, 2020	In a move of exceptional operational security, the perpetrators voluntarily remove the SUNBURST code from the SolarWinds development environment.
December 8, 2020	Cybersecurity company FireEye publicizes its network breach and the theft of its Red Team tools.

December 12, 2020	A FireEye executive informs the SolarWinds CEO that the initial breach originated from the Orion platform
December 13, 2020	Official announcements are issued by FireEye, SolarWinds, and government agencies. The incident receives global publicity.
December 15, 2020	Microsoft and GoDaddy, in collaboration with FireEye, seize control of key C2 domains, effectively activating a killswitch in SUNBURST.

The analysis of the attack can be categorized into four categories which align perfectly with MITRE ATT&CK framework.

Stage 1: Initial Access

Attackers avoided traditional attack methods toward final targets (e.g., spearphishing), choosing instead to strike the intermediate software. Access to victim environments was achieved entirely through the official Orion update process.

MITRE ATT&CK Tactic / Technique	Description and Application in the Attack
T1195.002 (Supply Chain Compromise: Software)	Distribution of malicious code (SUNBURST) embedded in official SolarWinds updates, bypassing corporate firewall checks.
T1078 (Valid Accounts)	For the initial penetration into SolarWinds itself, it is speculated that password guessing techniques or VPN system exploitation were used, creating valid internal user profiles.

Stage 2: Execution

Inserting Sunburst into the ORION was not a simple modification of files into SolarWinds repository, because this would be easily detected. Instead they developed a special implant named Sunspot, which was installed in the build server.

Sunspot constantly monitored the current processes of the OS. When it recognized the start of the Microsoft Visual Studio compilation tool (MsBuild.exe), it intervened instantly: it replaced a legitimate source code file with an altered version containing the SUNBURST backdoor. Once the compilation process was complete, SUNSPOT restored the original file, erasing any trace of the intervention. To ensure developers were not alerted, SUNSPOT calculated MD5 hashes of files before replacement and used #pragma commands to hide any warnings during compilation.

MITRE ATT&CK Tactic / Technique	Description and Application in the Attack
T1057 (Process Discovery)	SUNSPOT detected MsBuild.exe by calculating cryptographic hashes of process names and comparing them to the built-in value 0x53D525.
T1053.005 (Scheduled Task/Job)	Persistence of SUNSPOT on the build server was achieved through scheduled tasks that ran automatically at system startup.

Stage 3: Defense Evasion & C2

After installing the infected updates, Sunburst backdoor operated with maximum coverage. It stayed silent for a period of two weeks. Subsequently, it conducted extensive Anti-analysis environment checks by examining process names, files, active directories to ensure the system was not a sandbox.

Communication with command and control C2 servers was complex. Sunburst operated in passive and active states. In passive state, it used a domain generation algorithm for the creation of random subdomains, in which it encoded the victims local network domain name. Network traffic was camouflaged to look legit Orion Improvement Program protocol. Only if the

target was high value did sunburst move to active mode, utilizing HTTP communication to receive special commands.

MITRE ATT&CK Tactic / Technique	Description and Application in the Attack
T1562.001 (Disable or Modify Tools)	Attackers often disabled local logging services (e.g., using AUDITPOL) just before executing commands, restoring them afterward.
T1048 (Exfiltration Over Alt. Protocol)	Combined use of DNS (for latent communication) and HTTP (for direct commands and data extraction), always mimicking SolarWinds' OIP.

Stage 4: Lateral Movement, Post-Exploitation, and the Golden SAML Technique

When access was established, the perpetrators stopped using SUNBURST and deployed the TEARDROP and Raindrop tools into system memory. These tools were used as "loaders" for executing custom versions of Cobalt Strike, completely separating the subsequent attack from the Orion process (an OpSec measure).

Next, the APT29 team demonstrated immense skill in targeting Identity and Access Management (IAM) systems. The most advanced technique used was Golden SAML. In this attack, the intruders first penetrated the victim organization's local Active Directory Federation Services (AD FS) servers, gaining access to the Distributed Key Manager (DKM) container. From there, they stole the private token-signing certificate.

With this key in their possession, the attackers gained the ability to forge valid Security Assertion Markup Language (SAML) tokens on behalf of the server. This meant they could create a cryptographically valid login request stating, for example, that a user with Global Administrator privileges had already been successfully identified. In this way, they breached victims' Cloud

infrastructures (such as Microsoft 365 and AWS), completely bypassing multi-factor authentication (MFA) and gaining seamless access to corporate documents and emails.

MITRE ATT&CK Tactic / Technique	Description and Application in the Attack
T1606.002 (Forge Web Credentials: SAML Tokens)	Forgery of SAML tokens via stolen AD FS keys. Allows the creation of valid sessions in Cloud services bypassing MFA.
T1552.004 (Private Keys)	Search and theft of PKI certificates and private encryption keys from local directory systems.
T1021 (Remote Services)	Use of protocols such as RDP and administrative shares for lateral movement in internal networks.
T1484.002 (Domain Trust Modification)	Modification of federation trust settings in Azure AD to accept forged tokens created by attackers.
T1114.002 (Email Collection)	Use of PowerShell commands (like New-MailboxExportRequest) or ApplicationImpersonation assignment for bulk collection of corporate emails from M365.

Part C:

Causes of Delayed Detection, Protection Evaluation, and the "solarwinds123" Hypothesis

Reasons for the delayed Detection:

Despite the advanced SOC in targeted government and private networks, the attacked remained invisible for approximately nine months. This weakness was not due to the lack of security tools but to the attackers clever exploit techniques.

Primarily, the DLL files containing the Suburst were introduced into the compilation process by sunspot and then signed with solarwinds official digital certificate. Modern Endpoint Detection and Response (EDR) systems and antivirus programs are programmed to provide a high index of trust to software bearing valid cryptographic signatures from known manufacturers. Since the operating system recognized the application as legitimate, security checks were relaxed.

Additionally, the nature of Orion as a network management tool inherently justifies its continuous network communication with external servers, as well as its operation with elevated privileges. Attackers camouflaged C2 communication within the company's legitimate OIP protocol. In an organization with thousands of terminals, this movement was easily lost in the general "noise" of telemetry. Furthermore, APT29 attackers used IP addresses through VPN services geographically located in the same country as each victim, preventing alerts due to "impossible travel" activity. The continuous use of separate, specialized Cobalt Strike implants for each victim ensured there were no shared Indicators of Compromise (IOCs) that could link the different incidents.

The Role of the "solarwinds123" Password:

One of the most discussed parameters of the attack was the extremely weak password "solarwinds123". During the hearings in front of the US house oversight committees, it was confirmed that the password was exposed in a GitHub repository. It was sitting there from June 2018 and was made for accessing a company FTP server. Company former CEO Kevin Thompson and current CEO Sudhakar Ramakrishna testified under oath that it was an interns error who violated company policy.

Consequently, the question arises: Did this password serve as the entry point for developing the SUNBURST backdoor? Based on investigative data, the answer is negative regarding direct causal correlation. SolarWinds representatives stated the password was used for a third-party manufacturer application that was not interconnected with corporate IT systems and the software development process. This view is reinforced by the level of complexity of the intrusion, which required deep knowledge of the compilation system rather than just access to a random FTP server.

However, the password leak is a symptom of broader operational pathology. As industry experts and committee members pointed out, blaming an intern does not justify the lack of automated repository check mechanisms, the absence of password complexity controls in production systems, and the non-application of the principle of least privilege. The fact that the password was accessible until November 2019 (overlapping with the start of the attackers' presence in September 2019) demonstrates serious gaps in the company's security culture. Although no direct link is proven, such vulnerabilities are primary targets in the initial reconnaissance stages performed by attackers.

Proposed Security, Prevention, and Detection Measures:

In order to defend against nation-state level supply chain attacks, a zero trust philosophy is required. If the following technical organizational measures had been implemented, the attack could have been way less serious and limited.

Software Supply Chain Management Frameworks:

The basis of defense is found in compliance with international standards. The U.S. National Institute of Standards and Technology (NIST) strengthened its guidance through two basic frameworks:

Proposed Framework	Subject and Implementation of Measures
NIST SP 800-161r1 (C-SCRM)	Cybersecurity Supply Chain Risk Management Framework. Requires organizations to develop detailed vendor risk assessment processes before and during collaboration with third-party providers.
NIST SSDF (SP 800-218)	Secure Software Development Framework. Applied by software manufacturers (like SolarWinds). Includes strict protection of the build environment and mandates maintaining Software Provenance

Implementation of SSDF requirements by collecting certificates of records for all code components, would create an alarm when sunspot replaced files. Also, using the software bill of materials SBOM it would offer a total transparency into the structure of the software.

Access Restriction and Segmentation

By placing Orion at the center of the network it provided unrestricted access. Strick Network Segmentation is required. Even management tools must be placed in isolation zones with strict

firewalls, limiting traffic only to necessary ip addresses. This would prevent sunburst from communicating with external C2 servers.

Countering Identity Forgery (Golden SAML Mitigations)

To prevent lateral movement and the Golden SAML technique, organizations must shield authentication services:

- Access Restriction (Tiering): Access to AD FS servers must be allowed exclusively through approved Privileged Access Workstations (PAW).
- Systematic Monitoring: Continuous auditing of AD FS event logs. Extracting a signing certificate is an extremely rare process in production environments and should immediately trigger a critical SOC alarm.
- Key Rotation: Regular rotation of signing certificates. Rapid and successive key changes immediately invalidate any forged SAML tokens created in the past.

In summary, the SolarWinds attack demonstrated that in the modern threat landscape, security does not end at perimeter protection. A holistic approach is required that ensures the inherent security of the production process (Secure-by-Design), promotes defensive separation of critical identities, and treats supply chain risk management as a critical pillar of corporate strategy. Only through continuous verification and zero-trust control can organizations defend against attacks of this magnitude

References:

1. Lessons Learned from the SolarWinds Hack: What Went Wrong & How Can Lawyers Help Mitigate the Risk of Cyberattacks - <https://www.acc.com/sites/default/files/2021-02/Lessons%20Learned%20from%20the%20SolarWinds%20Hack.pdf>
2. Use of LLMs, Gemini Deep Research, ChatGPT Deep Research, Claude Opus 4.6
3. The SolarWinds Attack: A Complete Analysis and the Path Forward - TerraZone, <https://terrazone.io/solarwinds-attack/>
4. How I Mapped the SolarWinds Cyber Attack with MITRE ATT&CK and What It Taught Me About Seeing... - Odunlade Adeola, <https://adeolaodunlade.medium.com/how-i-mapped-the-solarwinds-cyber-attack-with-mitre-att-ck-and-what-it-taught-me-about-seeing-667995f6fc65>
5. SolarWinds and Related Supply Chain Compromise - Federal Energy Regulatory Commission, <https://www.ferc.gov/sites/default/files/2021-07/SolarWinds%20and%20RelatedSupply%20Chain%20Compromise%20White%20Paper%201.pdf>
6. SolarWinds Supply Chain Attack | Fortinet, <https://www.fortinet.com/resources/cyberglossary/solarwinds-cyber-attack>
7. Mapping the SolarWinds Cyber Attack with the MITRE ATT&CK Framework - Medium,

<https://medium.com/@humairadamu/mapping-the-solarwinds-cyber-attack-with-the-mitre-att-ck-framework-aaa3cf56339b>

8. New Findings From Our Investigation of SUNBURST - SolarWinds Blog,
<https://www.solarwinds.com/blog/new-findings-from-our-investigation-of-sunburst>
9. Solarwinds Attack | The Belfer Center for Science and International Affairs,
<https://www.belfercenter.org/publication/solarwinds-attack>
10. Federal Response to SolarWinds and Microsoft Exchange Incidents - NIST Computer Security Resource Center <https://csrc.nist.gov/csrc/media/Presentations/2022/gao-report-federal-response-to-solarwinds/Franks%20-%20SolarWinds%20and%20MS%20Exchange%20Incidents%20-%203.9.2022%202pm.pdf>
11. An Investigative Update of the Cyberattack - SolarWinds Blog
<https://www.solarwinds.com/blog/an-investigative-update-of-the-cyberattack>